

INFORMATION DISCLOSURE

Information Disclosure is when a web application fails to properly protect confidential information, which causes revealing sensitive information or data of the users or anything related to users to any third party. This type of attack is aimed at acquiring system specific information about a web site including software distribution, version numbers, and patch levels. The acquired information might also contain the location of backup files or temporary files. Most web sites will disclose some amount of information. The more information that an attacker gets about a web site, the easier the system will be to penetrate. Information disclosure threats involve the exposure or interception of information to unauthorised individuals. An example is when a user can read a file that they were not granted access to, or the ability of an intruder to read data in transit between two computers.



Types of Information disclosure attacks

- Directory Indexing

The above disclosure exploits a function in a web server that lists all the files within a requested directory if the normal base file is not present.

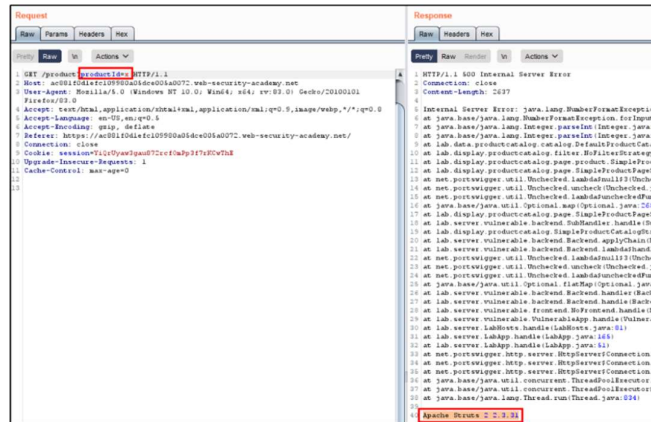
Index of /

Name	Last modified	Size	Description
 secret/	2017-01-27 15:40	-	
 priv/	2017-01-27 15:41	-	
 edit/	2017-01-27 15:40	-	
 dir1/	2017-01-27 15:40	-	
 config.php	2017-01-27 15:40	11K	

Apache/2.4.23 (Win64) PHP/5.6.25 Server at localhost Port 80

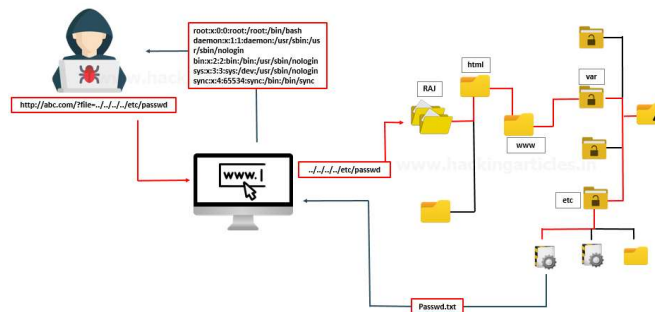
- Information Leakage

The above disclosure exploits a web site that reveals sensitive data, such as developer comments or error messages.



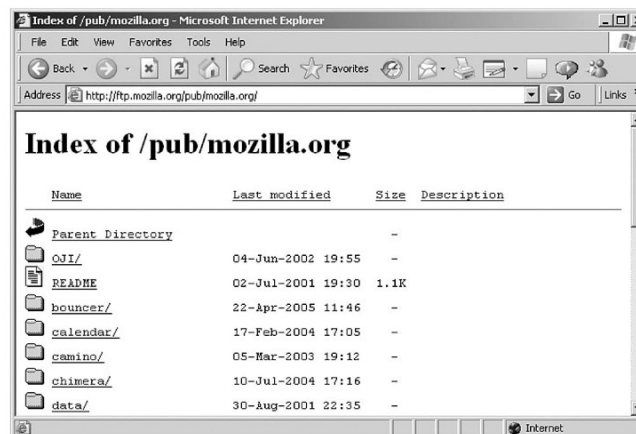
- Path Traversal

The above disclosure forces access to files, directories, and commands that are located outside the web document root directory.



- Predictable Resource Location

The above disclosure uncovers hidden web site content and functions.



Types of Information disclosure URLs

- **HTTP_Apache_ServerInfo**
It searches for an HTTP request with the Apache server-info handler specified.
- **HTTP_Apache_ServerStatus**
It searches for an HTTP request with the Apache server-status handler specified.
- **HTTP_Apache_Trailing_Slash**
It detects attempts to view the source of PHP pages by exploiting a vulnerability that exists when the PHP site is hosted on a Windows samba file share and the requested page name is appended with a \ to the .php file extension in the URL.
- **HTTP_Bash_Shell_History**
It detects HTTP URLs that contain */.bash_history or */.history. This signature replaces HTTP_ShellHistory.
- **HTTP_ColdFusion_Debug**
It detects an HTTP URL that contains the string *.cfm and that also has a parameter/value pair of mode=debug in the query string.
- **HTTP_FileTypeLnk**
It detects an attempt to access a .lnk file (/ */*.lnk). Under some circumstances, an attacker might use such a file to gain access to privileged information on the client system. This signature replaces HTTP_IE3_URL.
- **HTTP_FileTypeUrl**
It detects an attempt to access a .url file (/ */*.url). Under some circumstances, an attacker might use such a file to gain access to privileged information on the client system. This signature replaces HTTP_IE3_URL.
- **HTTP_FrontPage_Authors**
It detects a request for the author's password.
- **HTTP_FrontPage_PWD**
It detects a request for the Administrator's password.

- **HTTP_IIS_Obtain_Code**
It detects HTTP GET requests that include the string `+.htr`, which might indicate an attempt by an attacker to view the source of files on the web server.
- **HTTP_IIS_Track**
It searches for an HTTP request that sets track. This leads to returning sensitive information from the server. IIS does not properly log this request.
- **HTTP_IIS_Trailing_Incomplete_Unicode**
The server source code often contains hidden passwords, hidden file names, or easy-to-discover bugs. The attacker can then use this hidden information to break into the server.
- **HTTP_JSP_SourceRead**
It detects a URL ending with the file name extension `.jsp` or `.jhtml` where any of the letters in the extension are not lowercase.
- **HTTP_Microsoft_Error_Report**
It detects the reporting of a Windows application error, such as a crashed or stopped process.
- **HTTP_Netscape_List_Directories**
It detects the use of an HTTP INDEX request that Netscape Enterprise web servers support. An attacker can use this request to gain access to sensitive information.
- **HTTP_Netware_DirList**
It detects an HTTP command consisting of `get` (lowercase) and a URL of `/`.
- **HTTP_Orion_JSP_SourceRead**
It detects a URL ending with the file name extension `.jsp` (`.jsp` followed by a space).
- **HTTP_Passwd_Txt**
It detects HTTP GET requests for the `passwd.txt` file.
- **HTTP_PHP_Addslashes_ViewFiles**
It detects a specially-crafted URL that might be used to view arbitrary files on the system.

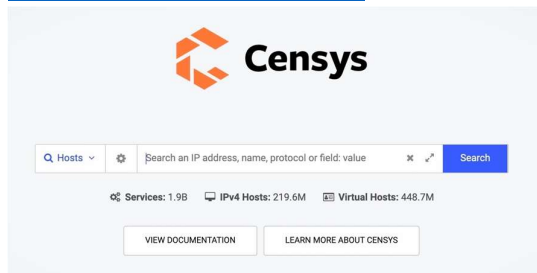
- **HTTP_PHPNuke_Admin_Overwrite**
It detects an HTTP URL that contains the string `*/admin.php`, and also uses a query string that starts with `upload`.
- **HTTP_POST_Filename_passwd**
It detects an HTTP POST command that references a file name that includes the string `*/passwd` or the string `*/shadow`.
- **HTTP_POST_Filename_sam**
It detects an HTTP POST command that references a file name that includes the string `*/sam._`.
- **HTTP_PsaPhp_RevealSource**
It detects HTTP URLs that have a path that begins with `/~` and that references a file name that contains the string `*.php`.
- **HTTP_Server_ID**
It detects server ID requests and lists any information disclosed as a result of this command.
- **HTTP_Tunnel_Not_TLS_or_SSL**
It detects an HTTP CONNECT request where the tunnelled data does not immediately begin with a SSL or TLS hello exchange. While this signature does not indicate an attack on your network, it does indicate traffic that might be considered suspicious in an environment where HTTP tunnelling is expected only by HTTP proxies to secure web sites.
- **HTTP_Unix_Passwords**
It detects an HTTP GET request for a `passwd` or `shadow` password file.
- **HTTPS_Proxy_Info_Disclosure**
It detects Basic Authentication over a proxy server for HTTPS communications that might lead to possible information disclosure.
- **Tivoli_LCF_File_Read**
It detects an HTTP GET request to manipulate the Tivoli® LCF log file parameter, possibly to read files with elevated privileges.

These are the URLs (Signatures) using which an attacker can disclose the sensitive information.

We can use various tools to find the information disclosure vulnerability. These tools include the following:

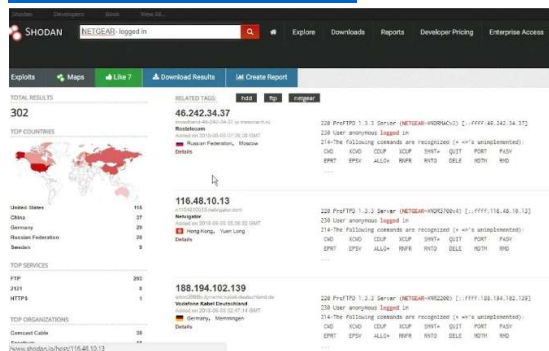
- Censys

<https://search.censys.io/>



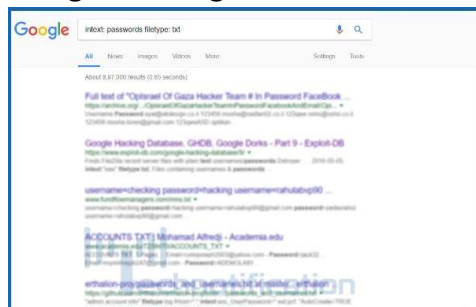
- Shodan

<https://www.shodan.io/>



- Dorking sites like

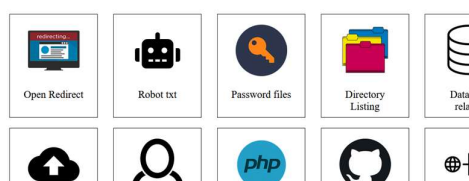
Google dorking



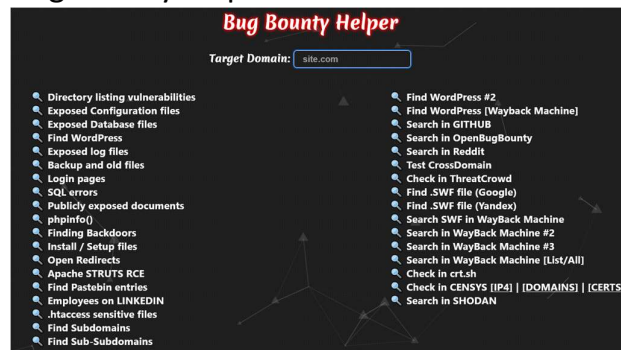
Investigator



Investigator helps you quickly check and gather information a domain name.



Bug Bounty helper



Bug Bounty Recon



GitHub Dorking

GitHub Dork Helper

From URL: Get Keywords

Target : Generate Link

.mlab.com+password

WFCClient+Password+extension:ica

access_key

access_token

admin_pass

admin_user

algolia_admin_key

algolia_api_key

alias_pass

alicloud_access_key

amazon_secret_access_key

☐ .mlab.com+password

☐ WFCClient+Password+extension:ica

☐ access_key

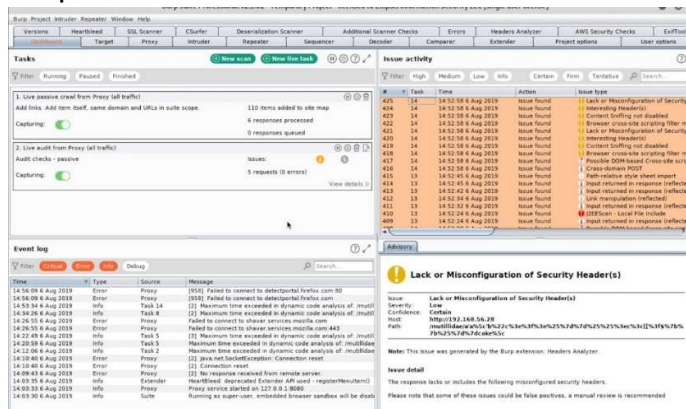
☐ access_token

☐ admin_pass

- Dirsearch

```
root@kali:~# ./dirsearch.py -u www.100security.com.br -e *
dirsearch v0.3.7
Extensions: db | Threads: 10 | Wordlist size: 5151
Error Log: /dirsearch/logs/errors-17-02-20_16-36-49.log
Target: www.100security.com.br
[16:36:53] Starting:
[16:37:23] 406 - 226B - /.adminer.php.swp
[16:37:23] 406 - 226B - /.bak
[16:37:23] 406 - 226B - /.bash_history
[16:37:48] 406 - 226B - /.cc-ban.txt.bak
[16:38:11] 406 - 226B - /.config.php.swp
[16:38:11] 406 - 226B - /.configuration.php.swp
[16:38:36] 301 - 0B - /.dump -> http://www.100security.com.br/dumpsec-aud
toria-de-seguranca/
1.51% - Last request to: .dat
```

- Burpsuite



Using the above tools, we can find the information disclosure vulnerability.

References

- <https://www.ibm.com/docs/en/snips/4.6.0?topic=categories-information-disclosure-attacks>
- <https://portswigger.net/web-security/information-disclosure/exploiting>
- https://pdf-insecurity.org/download/pdf-dangerous-paths/PDF_Features_Disclosure.pdf
- https://www.akitasecurity.nl/advisory/AK20050601/powerpoint_ie_reload_information_disclosure_vulnerability.html
- https://martinfowler.com/articles/agile-threat-modelling/Information_Disclosure-STRIDE_Threat_Modelling_Card.pdf